

# Survey Paper

## Implementation of a Secure CI/CD Pipeline Using DevOps Tools

### 1.Objectives:

1. **To design and implement a Secure DevOps CI/CD pipeline** that integrates security practices throughout the software development lifecycle.
  2. **To automate vulnerability detection and security testing** using Static Application Security Testing (SAST) and Dynamic Application Security Testing (DAST).
  3. **To ensure secure application deployment** using containerization and orchestration technologies.
  4. **To monitor and detect security threats continuously** using monitoring and logging tools.
- 

### 2.Tools and Technologies

| Tool                        | Category                 | Purpose                                                                                    |
|-----------------------------|--------------------------|--------------------------------------------------------------------------------------------|
| Git                         | Version Control          | Track and manage source code changes                                                       |
| GitHub                      | Repository Hosting       | Store and manage project code                                                              |
| Jenkins                     | CI/CD Tool               | Automate build, test, and deployment                                                       |
| Docker                      | Containerization         | Package application into containers                                                        |
| Kubernetes                  | Container Orchestration  | Manage and scale containers                                                                |
| Terraform                   | Infrastructure as Code   | Automate infrastructure creation                                                           |
| SonarQube                   | SAST Tool                | Detect vulnerabilities in source code                                                      |
| OWASP ZAP                   | DAST Tool                | Scan running application for vulnerabilities                                               |
| Trivy                       | Container Security       | Scan container images for vulnerabilities                                                  |
| Prometheus                  | Monitoring Tool          | Collect system metrics                                                                     |
| Grafana                     | Visualization Tool       | Display monitoring dashboards                                                              |
| Microsoft Azure / AWS Cloud | Cloud Computing Platform | Provide cloud infrastructure to host, deploy, and manage applications and DevOps pipelines |

---

### **3. Methodology :**

#### **Step 1 – Source Code Management**

Developers write application code and push it to a **GitHub repository** using Git.

#### **Step 2 – Continuous Integration**

Jenkins automatically triggers the build process and runs **static code analysis using SonarQube**.

#### **Step 3 – Security Scanning**

Security tools such as **OWASP ZAP and Trivy** scan the application and container images for vulnerabilities.

#### **Step 4 – Containerization**

The application is packaged into a **Docker container** for consistent deployment.

#### **Step 5 – Deployment**

Containers are deployed and managed using **Kubernetes**, while infrastructure is provisioned using **Terraform**.

#### **Step 6 – Monitoring and Logging**

System performance and security metrics are monitored using **Prometheus and Grafana**.